

cw04b – DHCP i ochrona przed obcym serwerem DHCP

Rodzaj materiału	Instrukcja dla uczestnika
Punkt programu	4.2 Bezpieczeństwo DHCP – DHCP Snooping
Czas realizacji	90 minut
Plik Packet Tracer	cw04b_dhcp_snooping.pkt · Cisco Packet Tracer

1. Cel ćwiczenia

Po wykonaniu ćwiczenia uczestnik potrafi:

- skonfigurować serwer DHCP na przełączniku warstwy 3 i obsłużyć z niego kilka sieci VLAN,
- wyjaśnić, dlaczego serwer DHCP musi być w sieci klienta albo korzystać z przekazywania zapytań,
- przeprowadzić i opisać atak polegający na uruchomieniu w sieci obcego serwera DHCP,
- włączyć mechanizm DHCP Snooping i prawidłowo wskazać porty zaufane,
- odczytać tablicę powiązań budowaną przez ten mechanizm i wyjaśnić jej znaczenie,
- rozpoznać sytuację, w której DHCP Snooping został włączony nieprawidłowo i sam odciął klientom dostęp do adresacji.

2. Scenariusz

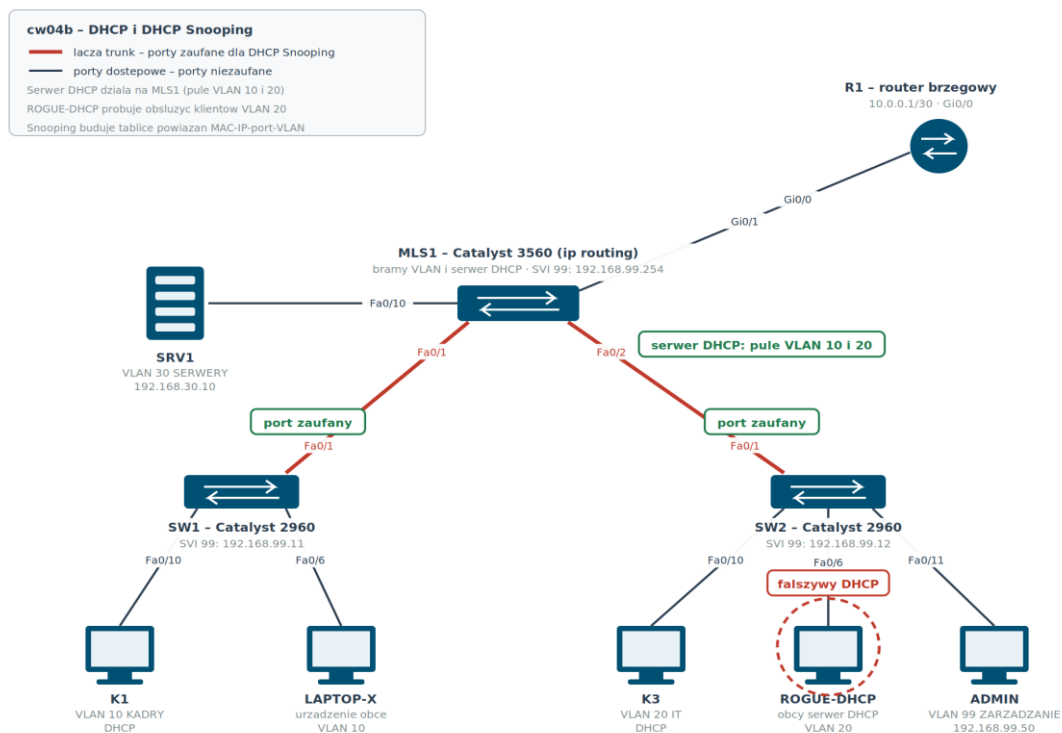
W KRZAK CORP adresy przydzielane są ręcznie. Przy trzydziestu stanowiskach to jeszcze działało, przy stu przestało: rosły pomyłki, zdarzają się adresy powtórzone, a każda zmiana serwera DNS wymaga obejścia wszystkich komputerów. Zapadła decyzja o uruchomieniu serwera DHCP na przełączniku MLS1, który i tak jest bramą dla wszystkich sieci VLAN.

Zaraz po wdrożeniu pojawił się problem innego rodzaju. Pracownik działu IT podłączył pod biurkiem router domowy, żeby mieć dodatkowe gniazdo. Urządzenie miało domyślnie włączony serwer DHCP i zaczęło odpowiadać na zapytania komputerów z całej sieci działu. Część pracowników otrzymała adresy z sieci 192.168.0.0/24 i bramę wskazującą na to urządzenie – przestali widzieć zasoby firmowe, a ich ruch zaczął przechodzić przez sprzęt, nad którym dział IT nie ma kontroli.

Wymagania:

1. Stacje w sieciach VLAN 10 i VLAN 20 mają otrzymywać adresację automatycznie z przełącznika MLS1.
2. Pierwsze pięćdziesiąt adresów każdej sieci pozostaje zarezerwowane dla urządzeń z adresacją stałą.
3. Odpowiedzi DHCP mogą pochodzić wyłącznie z kierunku, w którym faktycznie znajduje się serwer.
4. Urządzenie podłączone do gniazda użytkownika nie może pełnić roli serwera DHCP.
5. Przełącznik ma prowadzić ewidencję przyznanych adresów wraz z portem, na którym dany klient się znajduje.

3. Topologia i dane wejściowe



Rysunek 1. Ścieżka zapytania DHCP i miejsce podłączenia obcego serwera

Rola	Urządzenie	Szczegóły
Serwer DHCP	MLS1	Pule dla sieci VLAN 10 i VLAN 20; interfejsy SVI tych sieci są jednocześnie bramami klientów
Router brzegowy	R1	Gi0/0 o adresie 10.0.0.1/30 – w tym ćwiczeniu nie uczestniczy w DHCP
Klienci	K1 (VLAN 10), K3 (VLAN 20)	Ustawione na pobieranie adresu automatycznie
Obcy serwer	ROGUE-DHCP	Port Fa0/6 przełącznika SW2, sieć VLAN 20
Adresacja stała	SRV1, ADMIN	192.168.30.10 oraz 192.168.99.50 – poza zakresem puli

Tabela 1. Role urządzeń w ćwiczeniu

Parametr	VLAN 10 KADRY	VLAN 20 IT
Sieć	192.168.10.0/24	192.168.20.0/24
Brama (SVI na MLS1)	192.168.10.254	192.168.20.254
Adresy wyłączone	192.168.10.1 – 192.168.10.50	192.168.20.1 – 192.168.20.50
Adresy wyłączone (koniec)	192.168.10.200 – 192.168.10.254	192.168.20.200 – 192.168.20.254
Serwer DNS	8.8.8.8	8.8.8.8
Nazwa domeny	krzak.pl	krzak.pl

Tabela 2. Parametry pul adresowych

Uwaga: Router R1 ma już skonfigurowaną trasę statyczną do sieci wewnętrznych przez adres 10.0.0.2, a przełącznik MLS1 – trasę domyślną przez 10.0.0.1. Routing nie jest przedmiotem tego ćwiczenia.

4. Część 1 – Serwer DHCP na przełączniku MLS1

Zaczynamy od wyłączenia adresów, które nie mogą zostać przydzielone automatycznie. Dobrą praktyką jest zadeklarowanie ich przed utworzeniem puli: pula obejmuje całą sieć i dopiero wyłączenia ją zawężają, a klient, który zgłosi się w chwili, gdy pula już istnieje, a wyłączeń jeszcze nie ma, może dostać adres przewidziany dla urządzenia z adresacją stałą.

MLS1 – pule adresowe

```
MLS1# configure terminal
MLS1(config)# ip dhcp excluded-address 192.168.10.1 192.168.10.50
MLS1(config)# ip dhcp excluded-address 192.168.10.200 192.168.10.254
MLS1(config)# ip dhcp excluded-address 192.168.20.1 192.168.20.50
MLS1(config)# ip dhcp excluded-address 192.168.20.200 192.168.20.254

MLS1(config)# ip dhcp pool VLAN10_KADRY
MLS1(dhcp-config)# network 192.168.10.0 255.255.255.0
MLS1(dhcp-config)# default-router 192.168.10.254
MLS1(dhcp-config)# dns-server 8.8.8.8
MLS1(dhcp-config)# domain-name krzak.pl
MLS1(dhcp-config)# exit

MLS1(config)# ip dhcp pool VLAN20_IT
MLS1(dhcp-config)# network 192.168.20.0 255.255.255.0
MLS1(dhcp-config)# default-router 192.168.20.254
MLS1(dhcp-config)# dns-server 8.8.8.8
MLS1(dhcp-config)# domain-name krzak.pl
```

Zwróć uwagę na wiersz default-router. Bramą klienta jest interfejs SVI jego sieci VLAN na przełączniku MLS1 – adres .254. Wpisanie tu adresu innego urządzenia, na przykład routera R1, jest jednym z najczęstszych błędów w tej konfiguracji i skutkuje tym, że klient dostaje adres, ale nie osiąga niczego poza własną siecią.

Czasu dzierżawy z tabeli 2 nie ustawiasz – Packet Tracer nie obsługuje w puli polecenia lease. Na sprzęcie rzeczywistym osiem godzin ustawia polecenie lease 0 8 0.

Sprawdź, czy pule zostały utworzone:

MLS1 – weryfikacja

```
MLS1# show ip dhcp pool
MLS1# show running-config | section dhcp
```

5. Część 2 – Przydział adresów

Klient, który nie ma jeszcze adresu, wysyła zapytanie DHCPDISCOVER na adres rozgłoszeniowy 255.255.255.255. Rozgłoszenie nie wychodzi poza własną sieć VLAN, ale w tej topologii nie musi: MLS1 ma w sieciach VLAN 10 i VLAN 20 interfejsy SVI, więc odbiera zapytanie bezpośrednio. Pule wybiera na podstawie interfejsu, na którym zapytanie przyszło – adres 192.168.20.254 należy do sieci puli VLAN20_IT.

Ustaw teraz stacje K1 i K3 na pobieranie adresu automatycznie i sprawdź wynik:

Weryfikacja przydziału adresów

```
MLS1# show ip dhcp binding
MLS1# show ip dhcp pool
```

```
PC> ipconfig /all
```

Sprawdź, czy stacja otrzymała adres z właściwej sieci, bramę .254, serwer DNS 8.8.8.8 i nazwę domeny krzak.pl.

Poza symulatorem: W sieciach firmowych serwer DHCP zwykle działa na osobnej maszynie w serwerowni, poza sieciami klientów. Rozgłoszenie klienta do niego nie dotrze, dlatego bramę klienta konfiguruje się jako agenta przekazującego: interface vlan 10, a w nim ip helper-address z adresem serwera. Agent zamienia rozgłoszenie na pakiet skierowany do serwera i wpisuje w polu giaddr adres swojego interfejsu – po nim serwer wybiera pulę i wie, dokąd odesłać odpowiedź. Serwer musi mieć trasę powrotną do sieci klientów. Polecenie przekazuje także inne rozgłoszenia (między innymi TFTP i NetBIOS), co zawęży się poleceniami no ip forward-protocol udp. W Packet Tracerze przekazywanie zachowuje się niekonsekwentnie, dlatego w ćwiczeniu serwer działa na MLS1.

6. Część 3 – Obcy serwer DHCP

Do portu Fa0/6 przełącznika SW2 podłączono urządzenie ROGUE-DHCP, pełniące rolę routera domowego z włączonym serwerem DHCP. Skonfiguruj je tak, jak wyglądałoby urządzenie wyjęte z pudełka.

Parametr obcego serwera	Wartość
Sieć	192.168.0.0/24
Brama ogłaszana klientom	192.168.0.1
Serwer DNS ogłaszany klientom	192.168.0.1
Zakres przydzielany	192.168.0.100 – 192.168.0.150

Tabela 3. Ustawienia urządzenia ROGUE-DHCP

Packet Tracer: Rolę routera domowego pełni w pliku serwer (Server-PT). Zakładka Config → FastEthernet0: adres 192.168.0.1, maska 255.255.255.0. Zakładka Services → DHCP: Default Gateway 192.168.0.1, DNS Server 192.168.0.1, Start IP Address 192.168.0.100, Subnet Mask 255.255.255.0, Maximum Number of Users 51, przycisk Save, a następnie przełącznik Service w pozycji On.

Na stacji K3 zwolnij i pobierz adres ponownie. W Packet Tracerze wystarczy w zakładce Desktop przełączyć konfigurację na statyczną i z powrotem na DHCP. Powtórz próbę kilka razy i zanotuj, jaki adres otrzymuje stacja.

Wynik zależy od tego, która odpowiedź dotrze pierwsza. Obcy serwer stoi w tej samej sieci VLAN, tuż obok klienta, a prawdziwy serwer jest o dwa urządzenia dalej – w praktyce wygrywa ten bliższy. Nie ma tu żadnego mechanizmu rozstrzygania: klient przyjmuje pierwszą ofertę, jaka do niego trafi.

Sprawdź, co stacja faktycznie dostała, i co z tego wynika:

K3 – skutki przyjęcia obcej oferty

```
PC> ipconfig /all
PC> ping 192.168.30.10
PC> tracert 8.8.8.8
```

Zanotuj trzy skutki: adres z niewłaściwej sieci, brama wskazująca na urządzenie napastnika oraz serwer DNS pod jego kontrolą. Ostatni z nich jest najgroźniejszy – pozwala kierować użytkownika pod dowolny adres, mimo że w przeglądarce wpisze poprawną nazwę.

7. Część 4 – DHCP Snooping

Obroną jest mechanizm, który dzieli porty przełącznika na dwie grupy. Z portów zaufanych odpowiedzi serwera DHCP są przepuszczane. Z portów niezaufanych – odrzucane, niezależnie od tego, co urządzenie za nimi twierdzi. Zaufany jest wyłącznie ten kierunek, w którym rzeczywiście znajduje się serwer.

Konfiguracja na przełączniku dostępowym SW2:

SW2 – DHCP Snooping	
<pre>SW2# configure terminal SW2(config)# ip dhcp snooping SW2(config)# ip dhcp snooping vlan 10,20 SW2(config)# no ip dhcp snooping information option SW2(config)# interface fastEthernet 0/1 SW2(config-if)# ip dhcp snooping trust SW2(config-if)# exit SW2(config)# interface range fastEthernet 0/2 - 24 SW2(config-if-range)# ip dhcp snooping limit rate 10</pre>	
Polecenie	Działanie
ip dhcp snooping	Włącza mechanizm globalnie. Samo w sobie nie robi jeszcze nic.
ip dhcp snooping vlan 10,20	Wskazuje sieci VLAN objęte kontrolą. Bez tego polecenia mechanizm pozostaje bezczynny.
ip dhcp snooping trust	Oznacza port jako zaufany. Domyślnie wszystkie porty są niezaufane.
ip dhcp snooping limit rate 10	Ogranicza liczbę pakietów DHCP na sekundę – utrudnia wyczerpanie puli adresowej.
no ip dhcp snooping information option	Wyłącza dopisywanie do pakietu informacji o porcie (opcja 82), której w tej sieci nikt nie wykorzystuje.

Tabela 4. Elementy konfiguracji DHCP Snooping

Ważne: Opcja 82 jest najczęstszym powodem, dla którego po włączeniu DHCP Snooping klienci przestają otrzymywać adresy. Przełącznik dostępowy dopisuje do zapytania informację o porcie, ale pozostawia pole adresu agenta przekazującego (giaddr) równe zeru. Przełącznik Cisco, który odbierze takie zapytanie na porcie niezaufanym – tu MLS1 – domyślnie je odrzuca. Dopóki w sieci nie ma urządzenia, które tę opcję wykorzystuje, należy ją wyłączyć.

Powtórz konfigurację na przełączniku SW1 oraz na MLS1. Zastanów się, zanim wykonasz: który port jest portem zaufanym na każdym z tych urządzeń? Wskazówka – na przełączniku dostępowym zaufany jest port prowadzący w stronę serwera. Na MLS1 serwer działa na samym przełączniku – jego odpowiedzi nie wchodzi żadnym portem. Ustal, jaki status powinny mieć porty Fa0/1 i Fa0/2 prowadzące do przełączników dostępowych.

8. Część 5 – Tablica powiązań

Przy okazji kontrolowania odpowiedzi mechanizm zapisuje, jaki adres został przyznany jakiemu urządzeniu i na którym porcie. Powstaje w ten sposób tablica powiązań – zestawienie adresu MAC, adresu IP, sieci VLAN i portu.

SW2 – kontrola działania
<pre>SW2# show ip dhcp snooping SW2# show ip dhcp snooping binding SW2# show ip dhcp snooping statistics</pre>

Wyzwól ponowne pobranie adresu na stacjach K1 i K3 i sprawdź, czy wpis pojawił się w tablicy. Zwróć uwagę, że tablica powstaje wyłącznie dla klientów, którzy pobrali adres po włączeniu mechanizmu – urządzenia z adresem wpisanym ręcznie nigdy się w niej nie znajdują.

Uwaga: Ta tablica jest podstawą ćwiczenia cw04c. Mechanizm Dynamic ARP Inspection nie ma własnego źródła wiedzy o tym, do kogo należy adres IP – korzysta dokładnie z tych wpisów. Bez działającego DHCP Snooping nie da się go sensownie uruchomić.

9. Zadania do samodzielnego wykonania

Zadanie 2 – Sieć zarządzania

Rozważ, czy sieć VLAN 99 powinna być obsługiwana przez DHCP. Uzasadnij odpowiedź, odwołując się do roli tej sieci, a nie do wygody administratora.

Zadanie 3 – Wyczerpanie puli

Napastnik może wysyłać zapytania DHCP z tysiącami różnych adresów MAC, aż pula adresowa się wyczerpie i prawdziwi klienci przestaną otrzymywać adresy. Wskaż, które z poznanych mechanizmów – z tego ćwiczenia i z ćwiczeń poprzednich – utrudniają ten atak, i oceń, który z nich jest najskuteczniejszy.

Zadanie 4 – Rozbudowa sieci

Do sieci dołącza trzeci przełącznik dostępowy SW3, podłączony łączem trunk do MLS1. Wypisz komplet poleceń, które trzeba na nim wykonać, aby klienci otrzymywali adresy i aby port użytkownika nie mógł obsłużyć obcego serwera DHCP. Wskaż, co trzeba zmienić na MLS1.

Zadanie 5 – Diagnostyka

Użytkownik zgłasza, że jego komputer nie otrzymuje adresu. Zbuduj listę kroków diagnostycznych prowadzących od stacji do serwera, wymieniając przy każdym kroku polecenie i informację, jakiej w jego wyniku szukasz.

10. Pytania kontrolne

1. Dlaczego zapytanie DHCPDISCOVER dociera do serwera na MLS1 bez dodatkowej konfiguracji, a do serwera na routerze R1 by nie dotarło?
2. Skąd serwer DHCP na MLS1 wie, z której puli przydzielić adres klientowi z sieci VLAN 20?
3. Klient otrzymał adres od obcego serwera. Dlaczego adres serwera DNS jest w tej sytuacji groźniejszy niż błędny adres bramy?
4. Na SW1 i SW2 zaufany jest port Fa0/1. Które porty są zaufane na MLS1, skoro serwer DHCP działa na nim samym? Dlaczego?
5. Co się stanie, jeśli administrator włączy DHCP Snooping i zapomni oznaczyć port uplink jako zaufany?
6. Dlaczego urządzenie z adresem wpisanym ręcznie nie pojawia się w tablicy powiązań i jakie to ma znaczenie dla kolejnego ćwiczenia?

11. Weryfikacja końcowa

Ćwiczenie uznaje się za wykonane, gdy:

- stacje K1 i K3 otrzymują adresy z właściwych pul, z bramą wskazującą na interfejs SVI przełącznika MLS1,
- polecenie show ip dhcp binding na MLS1 pokazuje obie dzierżawy,
- po podłączeniu urządzenia ROGUE-DHCP stacja K3 nadal otrzymuje adres z puli firmowej,
- tablica powiązań na SW1 i SW2 zawiera wpisy dla klientów,
- na SW1 i SW2 zaufany jest wyłącznie port uplink Fa0/1, a na MLS1 – łączy do przełączników dostępowych Fa0/1 i Fa0/2,
- konfiguracja została zapisana na wszystkich urządzeniach.